

Security Group Documentation

This application uses **two security groups** to enforce **least-privilege network access** between the internet, the Application Load Balancer (ALB), and ECS Fargate tasks.

1 Application Load Balancer Security Group

Name: `alb-sg-<environment>`

Purpose

Allows public inbound traffic from the internet to the ALB and permits outbound traffic to ECS tasks.

Inbound Rules

Source	Protocol	Port(s)	Description
0.0.0.0/0	TCP	80	Allow HTTP traffic from the internet
0.0.0.0/0	TCP	443	Allow HTTPS traffic from the internet

Security Note:

- Port 443 should be used in production with ACM TLS certificates
- Port 80 can optionally redirect to 443

Outbound Rules

Destination	Protocol	Port(s)	Description
0.0.0.0/0	All	All	Allow ALB to forward traffic to ECS tasks

Why this is secure

- Only the ALB is exposed to the internet
- No direct access to application containers
- Supports WAF and TLS termination

2 ECS Service Security Group

Name: ecs-sg-<environment>

Purpose

Restricts application access so that **only the ALB can reach ECS tasks**.

Inbound Rules

Source	Protocol	Port(s)	Description
ALB Security Group	TCP	8080	Allow traffic only from ALB

Important:

- No CIDR blocks are allowed
 - Only traffic originating from the ALB security group is accepted
-

Outbound Rules

Destination	Protocol	Port(s)	Description
0.0.0.0/0	All	All	Allow ECS tasks to reach AWS services (ECR, CloudWatch, Secrets Manager)

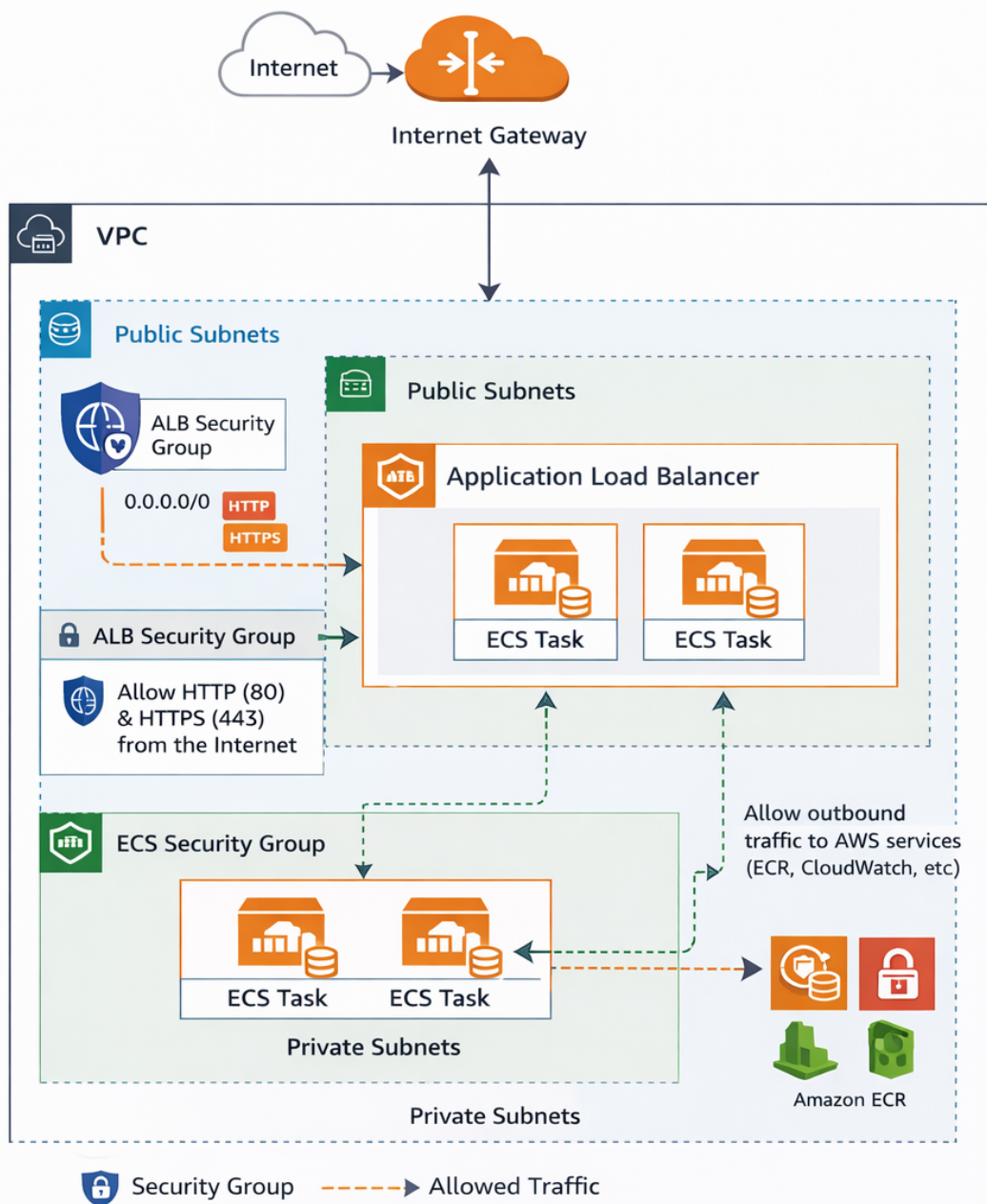
Why this is secure

- ECS tasks are **not internet-accessible**
- Prevents lateral movement inside the VPC
- Enforces a strict ALB → ECS trust boundary

Traffic Flow Summary

```
Internet
  |
  ▼
ALB (Public Subnet)
  | (allowed by ALB SG)
  ▼
ECS Tasks (Private Subnets)
  | (allowed by ECS SG)
  ▼
Application Container (Port 8080)
```

Architecture Diagram



Defense-in-Depth Summary

1. ALB Security Group allows public HTTP(S) traffic via ports 80 & 443.
2. ECS Security Group allows only traffic from the ALB, keeping the ECS tasks private.
3. ECS tasks allowed outbound to AWS services (ECR, CloudWatch, Secrets Manager) only.

Defense-in-Depth Benefits

Layer	Protection
Network	Security Groups restrict traffic flow
Subnet	Public vs Private isolation
IAM	Least-privilege task and execution roles
Load Balancer	Health checks & TLS termination
Observability	CloudWatch + New Relic

Terraform Reference (for traceability)

```
# ALB Security Group
ingress {
  from_port    = 80
  to_port      = 80
  protocol     = "tcp"
  cidr_blocks = ["0.0.0.0/0"]
}

# ECS Security Group
ingress {
  from_port    = 8080
  to_port      = 8080
  protocol     = "tcp"
  security_groups = [aws_security_group.alb.id]
}
```

Compliance & Best Practices Alignment

- ✓ Principle of Least Privilege
- ✓ Zero Trust between tiers
- ✓ AWS Well-Architected Framework
- ✓ CIS AWS Foundations
- ✓ Production-ready for SOC2 / ISO 27001 reviews